



FUNDAMENTALS OF INFORMATION SECURITY

SESSION 4

COURSE CODE:

CYBE 6123

LECTURER: **NGUEMETA NATHANIEL**



Business Drivers of Information

Objective of the session

- Risk management's importance to organizational strategy
- How the business impact analysis (BIA), business continuity plan (BCP), and disaster recovery plan (DRP) differ from one another and how they are alike
- How to describe the impact of risks, threats, and vulnerabilities on an organization
- How to close the information security gap
- How to mitigate risk and achieve compliance with laws, regulations, and requirements
- How to protect individual private data
- How to mitigate the risk of mobile workers and use of personal devices

Importance of Risk Management to an Organization



- Risk management implies an ongoing process of identifying, assessing, prioritizing, and addressing risks.
- A risk will result in a material impact to an organization
- Risk management ensures **proactive planning** well in advance of events occurring
- Risk management activities, should align with the organization's strategic goals
- Security controls that assist an organization in meeting objectives will be more easily accepted and respected
- Aligning security with strategic business objectives can drive business success with risk mitigation

Risk Management in an Organization

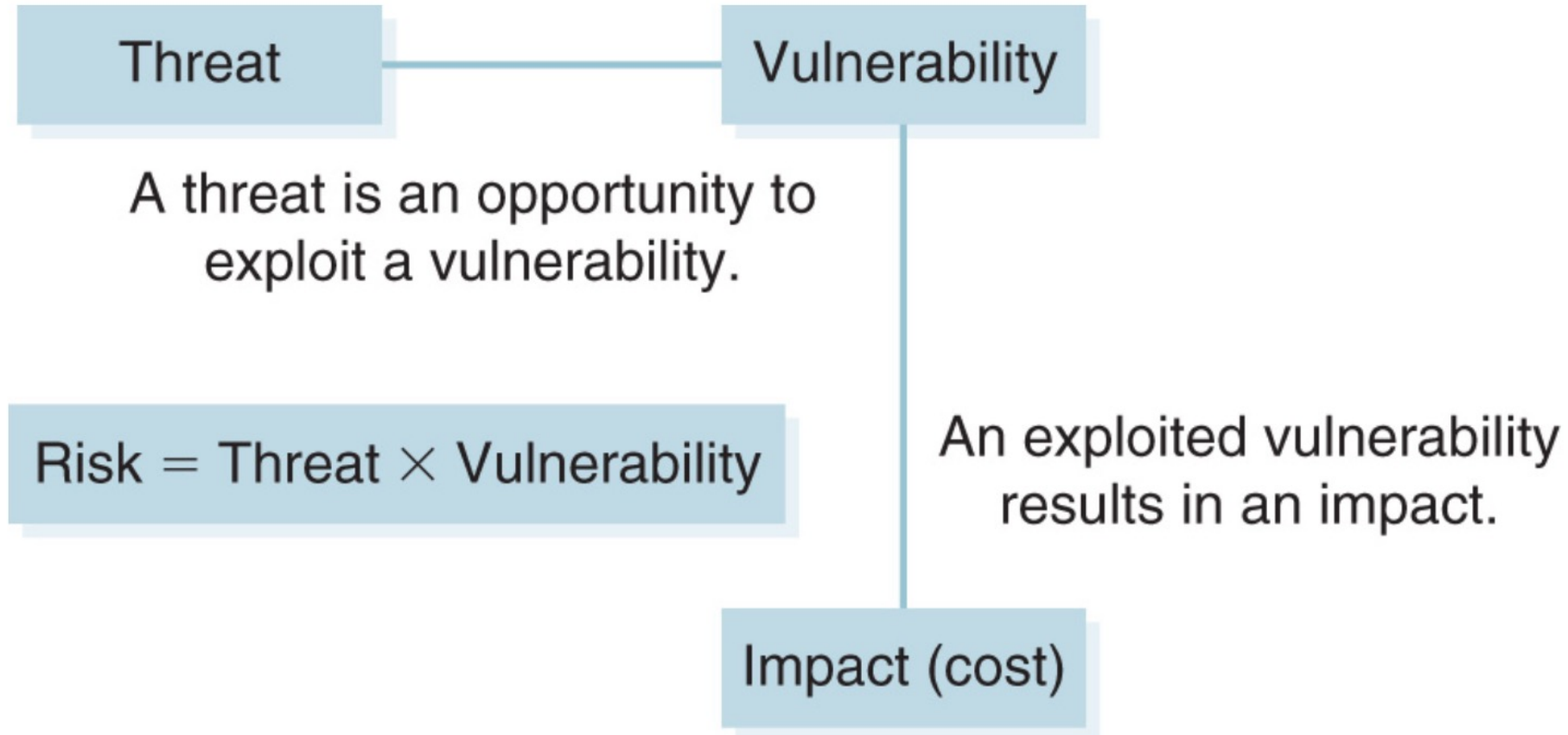


FIGURE 4-1 Risks, threats, and vulnerabilities.

Risk Management in an Organization



- Proper Risk management requires effective planning
- Planning should include all stages of the process, identifying, assessing responding appropriately
- Planning also requires understanding the assets that needs to be protected, and the risks
- Risks need to be identified in a proactive manner, and assessed based on the asset value
- A consistent risk methodology has to be established
- Effective planning requires establishment and regular tracking of the risk register



Introduction to BIA, BCP and DRP

Business Impact Analysis (BIA)

- BIA is a formal analysis of an organization's functions and activities that classifies them as either critical or noncritical
- It helps define a road map for business continuity and disaster recovery
- BIA prioritizes critical activities based on importance
- BIA helps an organization determine which functions to restore in what order if there is a major interruption
- BIAs also assist organizations with risk management and incident response planning

BIA Goals and Requirements

- **Recovery point objective (RPO)**
 - Defines target state of recovered data that allows an organization to continue normal processing
 - Determines the maximum amount of data loss that is acceptable for operations to resume
 - Provides direction on how to back up data
- **Recovery time objective (RTO)**
 - Expresses the maximum allowable time in which to recover the function
 - Specifying the requirements for recovery time helps determine the best recovery options
- **Business recovery requirements**
 - Identifies any other business functions that must already be in place for the specified recovery function to occur
- **Technical recovery requirements**
 - Defines the technical prerequisites that are needed to support each critical business function

Business Continuity Plan (BCP)



- BCP is a written plan for a structured response to any events that result in an interruption to critical business activities or functions
- BCP primarily addresses the processes, resources, equipment, and devices needed to continue conducting critical business activities
- BCP is about setting priorities, with the understanding that people always come first:
 - Safety and well-being of people
 - Continuity of critical business functions and operations, whether on-site or offsite, manual, or dependent on IT systems
 - Continuity of components within the seven domains of an IT infrastructure

Elements of a Business Continuity Plan



- Statement defining the policy, standards, procedures, and guidelines for deployment
- Project team members with defined roles, responsibilities, and accountabilities
- Emergency response procedures and protection of life, safety, and infrastructure
- Situation and damage assessment
- Resource salvage and recovery
- Alternate facilities or triage for short- or long-term emergency mode of operations and business recovery

Disaster Recovery Plan (DRP)



- A DRP directs the actions necessary to recover resources after a disaster
- Part of a BCP and is necessary to ensure the restoration of resources required by the BCP to an available state
- Identifies events that could cause damage to resources that are necessary to support critical business functions
- Involves threat analysis and impact evaluation

Threat Analysis



- Identifying and documenting threats to critical resources
- Consider the types of possible disasters and the kind of damage they can cause
- Realistically evaluate the expected loss that can be incurred due to the damage
- Always assume that disasters may occur in groups and not only as single events
- Also consider that some disasters may open the way for others to happen

Impact Scenarios



- Identifying and document likely impact scenarios
- Impact scenarios need to consider wider outreach on all business processes
- Impact on dependent assets should also be considered
- Impact of threats can be analyzed collectively to create global picture

Disaster Recovery



The critical steps in responding to a disaster include the following:

- ***Ensure everyone's safety first***—No other resource is as important as people.
- ***Respond to the disaster before pursuing recovery***—Required response and containment actions depend on the nature of the disaster and may not have anything to do with the recovery effort.
- ***Follow the DRP, including communicating with all affected parties*** —Once the people are safe and the disaster responded to, recovery actions can be pursued.

Data-center alternatives for disaster recovery

OPTION	DESCRIPTION	COMMENTS
Hot site	Facility, with environmental utilities, hardware, software, and data, that closely mirrors the original data center	Most expensive option, least switchover time
Warm site	Facility with environmental utilities and basic computer hardware	Less expensive than a hot site but requires more time to load operating systems, software, data, and configurations
Cold site	Facility with basic environmental utilities but no infrastructure components	Least expensive option but at the cost of the longest switchover time because all hardware, software, and data must be loaded at the new site
Mobile site	Trailer with necessary environmental utilities that can operate as a warm or cold site	Very flexible, fairly short switchover time, and widely varying costs based on size and capacity

Data-center alternatives for disaster recovery



The critical steps in responding to a disaster include the following:

- **Ensure everyone's safety first**—No other resource is as important as people.
- **Respond to the disaster before pursuing recovery**—Required response and containment actions depend on the nature of the disaster and may not have anything to do with the recovery effort.
- **Follow the DRP, including communicating with all affected parties** —Once the people are safe and the disaster responded to, recovery actions can be pursued.

Validating a DRP



- **Checklist test**—A checklist test is the simplest type of DRP test. In this test, each participant follows steps on the DRP checklist and provides feedback.
- **Structured walk-through**—A structured walk-through, also called a tabletop exercise or a conference room test.
- **Simulation test**—In a simulation test, which is more realistic than a structured walk-through
- **Parallel test**—A parallel test evaluates the effectiveness of the DRP by enabling full processing capability at an alternate data center without interrupting the primary data center.
- **Full-interruption test**—The only complete test is a full-interruption test.

Preventive Components of a DRP



- Local mirroring of disk systems and use of data protection technology, such as a redundant array of independent disks (RAID) or storage area network (SAN) system
- Surge protectors to minimize the effect of power surges on delicate electronic equipment
- Uninterruptible power supply (UPS) and/or a backup generator to keep systems going in the event of a power failure
- Fire prevention systems
- Antivirus software and other security controls

Assessing Risks, Threats, and Vulnerabilities



- Developing comprehensive BCPs and DRPs necessitates full assessment the risks, threats, and vulnerabilities associated with an organization's critical resources
- Approaches to assessing risk include:
 - Risk Management Guide for Information Technology Systems (NIST SP800- 30)
 - Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE)
 - ISO/IEC 27005:2022 “Information Security Risk Management”
 - Méthode Harmonisé d'Analyse des Risques (MEHARI)

Bridging the Gap



- Despite best efforts, no collection of security controls is perfect
- Some vulnerabilities may also exist for which there are no controls
- To better address the missing aspects in security status, gap analysis is essential
- Gap analysis helps discover the aspects required by policy and processes for smooth operations (Expected state) which are missing in the existing controls (Current state)
- Gap analysis activities should be ongoing and should consist of regular reviews of day-to-day practices vis-à-vis the latest threat assessment
- Threats that are not addressed through at least one control indicate gaps in the security

Gap Analysis Steps

- Identifying the applicable elements of the security policy and other standards
- Assembling policy, standard, procedure, and guideline documents
- Reviewing and assessing the implementation of the policies, standards, procedures, and guidelines
- Collecting inventory information for all hardware and software components
- Interviewing users to assess knowledge of and compliance with policies
- Comparing the current security environment to policies in place Prioritizing identified gaps for resolution
- Documenting and implementing the remedies to conform to policies

Common reasons for Security Gaps

- Lack of security training, resulting in noncompliant behavior Intentional or negligent disregard of security policy
- Unintended consequence of a control or policy change
- Addition or modification of hardware or software without proper risk analysis
- Configuration changes that lack proper risk analysis
- Changes to external requirements, such as legislation, regulation, or industry standards, that require control changes

Security Compliance Laws and Standards

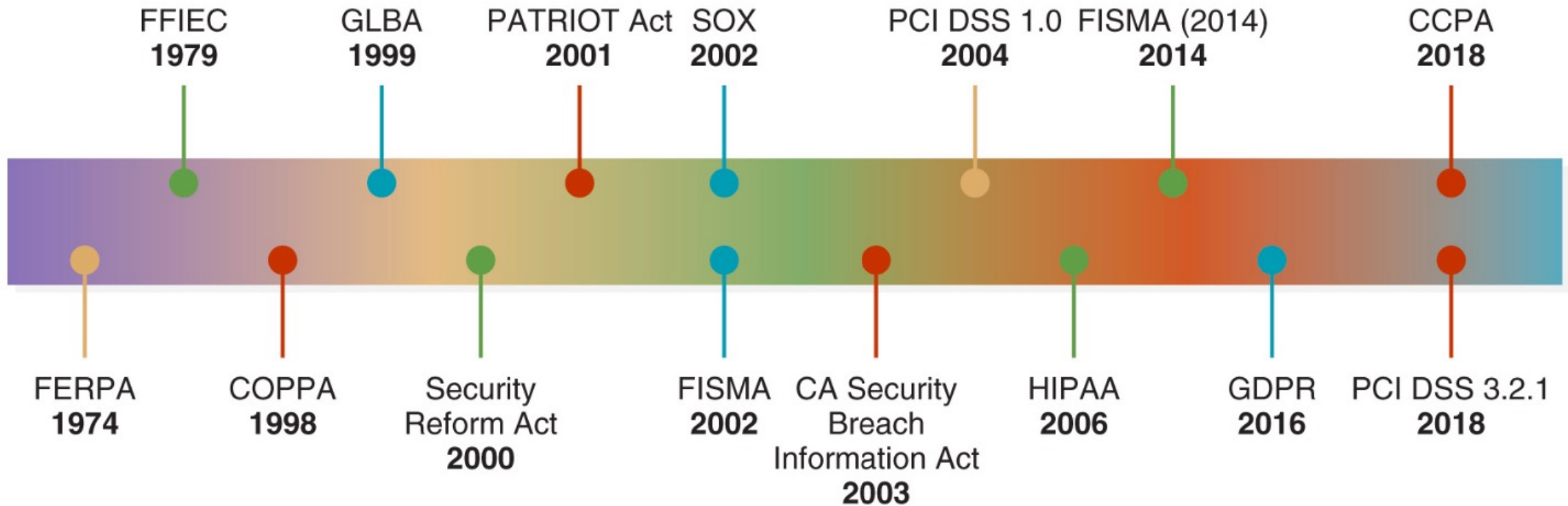


FIGURE 4-2 Security compliance laws and standards timeline.

Security Compliance Laws and Standards

- Family Education Rights and Privacy Act (FERPA)
 - It applies to all schools that receive funds under an applicable program of the U.S. Department of Education
- Federal Financial Institutions Examination Council (FFIEC)
 - Financial organizations assess their current risk profile and current cybersecurity maturity level by performing self-assessments based on this standard
- Children's Online Privacy Protection Act of 1998 (COPPA)
 - COPPA restricts how online information is collected from children under 13 years of age
- Gramm-Leach-Bliley Act (GLBA)
 - GLBA requires that financial institutions provide their clients a privacy notice regarding the use of their information
- Federal Information Security Management Act (FISMA)
 - FISMA was enacted in 2002 and required every federal agency to develop and maintain formal information security programs

Security Compliance Laws and Standards

- Health Insurance Portability and Accountability Act (HIPAA)
 - HIPAA requires that all medical records, billing, and patient information be handled in ways that maintain the patient's privacy
- European Union (EU) General Data Protection Regulation (GDPR) of 2016
 - The GDPR not only covers how data on EU citizens is collected, stored, and used, but also governs data that flows into or out of the EU
- Payment Card Industry Data Security Standard (PCI DSS v3.2.1)
 - The PCI DSS v3.2.1 is a comprehensive security standard that includes requirements for security management, policies, procedures, network architecture, software design, and other critical protective measures
- California Consumer Privacy Act (CCPA) of 2018
 - CCPA focuses on individual privacy and rights of data owners

Bring Your Own Devices

- Data ownership
- Support ownership
- Patch management
- Antivirus management
- Forensics
- Privacy
- Onboarding/offboarding
- Adherence to corporate policies
- User acceptance
- Architecture/infrastructure considerations
- Legal concerns
- Acceptable use policy
- Onboard camera/video

Assignment

- Provide 10 Endpoint and Device Security controls and explain briefly why each is important (do not copy what they do).
- Provide me the list of RAID options and what they do
- Complete and submit assessment.



Thank You